

availability, and resilience. Management should have an inventory of changes, including routine modifications, for back-out, resilience, and tracking purposes.

VII.B.3(b) Major Modifications

Major modifications include significant functional modifications to an existing system, conversion to a new system, or introduction of new systems, components, or data because of corporate mergers or acquisitions. In some cases, these may be referred to as “normal” changes as they are common but more complex than routine changes. These changes rely on extensive planning and additional management oversight as they often are longer-term; affect more of the entity’s systems, components, departments, and personnel; and incur higher cost. Major modifications should be implemented by adhering to a structured change management process, as noted in the [“Implementing Changes”](#) section of this booklet; however, some changes may need to go through the SDLC, particularly if there is any significant development activity. The goal of this process is to minimize risk, promote integrity and security, and maintain uninterrupted delivery of the service during and after a significant modification is implemented.

Entity personnel should assess risks related to major modification and all security-related changes. Key stakeholders should formally discuss these major modification requests and associated risks identified before approving the requests. Major modification policies and procedures should specify the decision criteria, accounting for requirements, feasibility, cost, project planning, software design, programming, testing, and implementation.

Entity personnel should determine the training required to make the conversion or major hardware and software upgrade successful. Training may start with ensuring that the major modification is adequately documented (e.g., new system information, user manuals, updates made to the system, and training information). Users affected by the changes should receive appropriate communication and training. Additionally, evaluation of the type, volume, and timing of training needs for each affected line of business and coordinate training programs with applicable third parties should be performed.

System conversions (and associated deconversions) are a major modification subset. A system conversion is a major change to an existing system and may involve migrating the system from one platform type to another (e.g., from on-premises to a cloud environment, or from one core provider to another). System conversions occur because of the introduction of new systems or corporate mergers and acquisitions. Changes to the foundation of the core platform may have additional effects throughout an entity’s operations, resulting in increased risk. Therefore, strong conversion controls (including documented conversion plans, adherence to entity change management processes, and comprehensive management oversight) are critical to prevent data corruption, performance degradation, and operational disruption. An improperly planned and executed conversion can disrupt the business and create inefficiencies, internal and external user dissatisfaction, and accounting problems, resulting in customer dissatisfaction, customer loss, and damaged entity, product, or service reputation.

Successful conversions rely on a comprehensive analysis of a conversion’s impact on existing operations (e.g., business processes and associated data processing, storage, and communication requirements), while accounting for interdependencies. Effective conversion policies, standards,

and procedures should include provisions for internal and external communication channels, appropriate reporting, and lines of authority for timely decision-making and issue resolution. Elements such as the following should be considered when planning a conversion:

- **Conversion team:** The conversion team should include stakeholders with knowledge of the interdependencies of the system being converted and ability to articulate how the new system solves issues or improves outcomes.
- **Strategic fit:** The new system should meet as many of the entity's strategic and business objectives as possible (to limit the need for additional products or add-ons).
- **Integration:** The new system should integrate with existing systems and components. This often involves using internal APIs to securely connect to internal systems across lines of business and using external APIs to securely connect with the entity's third parties (e.g., cloud providers, fintechs,²⁵⁰ third-party developers, partners, and customers).
- **Business intelligence:** The new system should enable comprehensive data analysis to support daily business activities and customer relationship management.
- **Ease of use:** The new system should be easily navigable and intuitive for entity personnel, which can improve workflow efficiency even if workflow efficiency was not an objective.
- **Evolution:** The new system should efficiently support evolving functional needs, changing technologies (e.g., evolution from on-premises to a cloud environment, artificial intelligence [AI], and quantum computing), and increasing capacity needs.
- **Compliance:** The new system should meet the entity's regulatory and internal policy requirements.
- **Security:** The new system should meet the entity's enterprise-wide information and cybersecurity requirements (e.g., security protocols, cyberattack monitoring, and resilience).
- **Training:** New system training should be available in a variety of formats (e.g., prerecorded, in-person, and virtual) and for a variety of users (e.g., end users and administrators).
- **Remote work flexibility:** An important variable to consider is whether the solution supports entity personnel remote work.
- **Conversion plans:** A key factor in conversion plans is ensuring the capability of personnel to map existing entity systems and components to the new system, to identify interdependencies, and to transfer data to the new systems. Additionally, an after-action review of the conversion can be useful for minimizing potential issues in future conversions.
- **Support:** Third parties should be able to support the conversion and provide ongoing support to the entity after the conversion.
- **Cloud:** Cloud-based solutions should meet applicable compliance requirements, include technology support, and integrate with the entity's existing systems and components.

Reference checking with a conversion partner's other clients can be helpful to learn the lessons from their conversions and improve the entity's conversion plan.

VII.B.3(c) *Emergency Modifications*

Emergency modifications correct severe and unexpected problems with systems and components

²⁵⁰ As previously stated, for purposes of this booklet, the term "fintech" refers to using technology in novel ways to provide financial services.

and minimize operational disruptions after an incident. Examples of situations that may require emergency modifications include the following.²⁵¹

- Natural disasters (e.g., floods, earthquakes, and storms) that disrupt critical facilities (e.g., data center outages and building evacuations for extended periods).
- Loss of a critical vendor or other supply chain component (e.g., cloud vendor, network vendor, telecom provider, electricity provider, and water system).
- IT incidents (e.g., denial of service attacks, malware, and network cable cuts).
- Emergency security patches released by vendors.
- Zero-day vulnerabilities that require timely configuration or other changes to mitigate risk until a patch can be developed, tested, and installed.

Entities that plan for emergency modifications are better able to limit negative effects on their business when situations like the above occur. To plan for emergency modifications, entities' policies, standards, and procedures should address expected emergency steps, such as the following:

- Specify who can declare an emergency.
- Designate a group (e.g., emergency change control review board) that can meet on extremely short notice to evaluate and approve proposed emergency modifications. The group could include senior leadership, critical line-of-business management, and key IT management.
- Create an emergency modification plan that includes a list of individuals in the emergency group (e.g., emergency change control review board) with contact information, and the procedures that are modified from standard change control and security processes to enable quick action.
- Plan for multiple methods of communication (e.g., in-person, phone, text, email, and collaboration site) in case the emergency occurs outside normal business hours, or a method is unavailable or insecure.
- Identify the responsible parties for enacting emergency changes and plan for their continuity.
- Compress certain phases of the implementation process to save time and still test, model, or simulate²⁵² before releasing the changes into the production environment. Any unwarranted delays in patching increases the risk that malicious actors or malware can exploit unpatched systems. For more information on exploits, refer to the *FFIEC IT Handbook's* "[Information Security](#)" booklet. Methods for reducing deployment time include the following:
 - Reducing the number of use cases addressed in testing and modeling, as well as planning to remediate issues with specific use cases.
 - Performing smaller scale testing in the modeling environment, such as deploying patches to 10 test machines instead of 50 or 500.

²⁵¹ Refer to CISA's [CRR Supplemental Resource Guide, Vol. 3: Configuration and Change Management, Version 1.1](#), and [CRR Supplemental Resource Guide, Vol. 5: Incident Management, Version 1.1](#).

²⁵² In computing, "modeling" or "[simulation](#)" is defined by *Merriam-Webster* as "the imitative representation of the functioning of one system or process by means of the functioning of another."

- Maintaining a list of users who have the authority and access rights to easily acclimate to emergency changes and can communicate temporary remediation tactics to their peers.
- Establish emergency minimum recovery point objectives with stakeholders to reduce the time required to perform system backups.
- Establish emergency downtime procedures (e.g., failover to alternate systems) that allow systems to be taken completely offline in emergencies. This helps minimize the need for outages and reboots in times of heavy use and expedites change completion.
- Perform periodic emergency drills in the test and modeling environment to prepare IT staff to deal with the stress of emergency modifications. Review the results of these drills and adjust emergency modification plans accordingly.

As identified above, testing emergency modifications before deployment is preferable to minimize potential disruptions. Effective management weighs the potential damage from an untested emergency change against the known damage from the subject issue to determine the level of testing required. Because testing is likely to be shortened, it is even more critical in emergency situations to have backup files and programs available and to establish a back-out plan before emergency modifications are implemented. Appropriate backups, established back-out plans and procedures, and detailed documentation provide the ability to reverse a change if it disrupts the system.

The number of emergency modifications should be kept to a minimum, and management should validate every emergency modification after implementation to determine whether it was correctly classified. Control should be maintained over personnel attempting to circumvent routine modification or major modification control processes by incorrectly classifying changes as emergencies to avoid resource constraints (e.g., time, personnel, and cost).

Detailed documentation enhances management's ability to analyze the effect of the emergency modification during a post-implementation review and verify that the change was deployed appropriately. Evaluations and documentation reviews of emergency modifications should be completed as soon as possible after implementation. Findings from these evaluations and reviews are used to improve existing change control policies, standards, and procedures.

For more information, refer to the *FFIEC IT Handbook's* "[Business Continuity Management](#)," "[Architecture, Infrastructure, and Operations](#)," "[Information Security](#)," and "[Management](#)" booklets.

VII.B.4 Change Management Documentation

Documentation related to changes allows management to analyze changes over time, learn lessons from those changes, and the effect of those changes on the entity's systems and components. Documentation of all changes (e.g., configuration changes, patches applied, system conversions, and emergency modifications) and their impact on systems and components should be maintained. Some examples of change-related documentation are covered in the following subsections.

VII.B.4(a) *Change Request Form*

Entities use change request forms to communicate the specifics of the change to all stakeholders for analysis purposes after the change is completed. The forms should provide a clear description of the requested changes as well as sufficient information for affected parties to understand the effect of a change. Change requests typically include elements such as the following:²⁵³

- Change request title.
- Change control identification number.
- Requestor's name.
- Request date.
- Detailed description of the change, including system, component, or configuration item involved.
- Proposed date and time of the change.
- Stakeholder groups affected.
- Business justification for the change.
- Resources (e.g., personnel, expertise, cost, and time) needed to implement the change.
- Expected impact of the change.
- Expected impact on resilience requirements for the asset.
- Backup procedures.
- Rollback (or back-out) procedures.
- Change urgency (e.g., low, medium, high, or emergency; and scheduled, urgent, or unscheduled).
- If the change is an emergency, justification for emergency change.
- Change control review board input, such as the following:
 - Preliminary assessment of change.
 - Decision (e.g., approved, rejected, more information required, or deferred) and further action if not approved.
 - Comments.
 - Authorized approver's signature and date.

VII.B.4(b) *Impact Analysis*

Documented impact analyses assist in communicating the effect of a change on the entity's information security. The impact analysis is generally maintained with and may be presented

²⁵³ Refer to CISA's [CRR Supplemental Resource Guide, Vol. 3: Configuration and Change Management, Version 1.1](#), and [CRR Supplemental Resource Guide, Vol. 5: Incident Management, Version 1.1](#). Also refer to NIST SP 800-128, [Guide for Security-Focused Configuration Management of Information Systems](#).

with the change request to serve as supporting information for decision purposes. The impact analysis typically includes elements such as the following:²⁵⁴

- Change request title.
- Change control identification number.
- Requestor's name.
- Request date.
- Analyst performing the impact analysis.
- Technical implications, such as other systems or components affected by the change or interface and integration issues (including with third parties).
- Functional impact, such as required changes to existing applications.
- Schedule impact.
- Financial impact, such as funding required to implement the change.
- People impact, such as end users, customers, expertise, and training.
- Security impact, including information security, cybersecurity, and physical security.
- Resilience impact.
- Entity risks from this change.
- Rollback (or back-out) implications.
- Alternatives to change and impact of not making the change.
- Authorized approval signature and date of approval.

VII.B.4(c) *Rollback or Back-Out Plan*

When implementing changes, there is always the potential that the deployment does not go as planned. When issues arise after a change, it may be necessary to rollback (or revert) to a prior version or level or back out a change and restore a system to its earlier state. Entity personnel should prepare for the possibility of a failed or incomplete deployment and have a plan with procedures to address the issues. Entity personnel should develop a rollback or back-out plan to reverse a failed deployment.

A rollback or back-out plan identifies the steps necessary for restoration to a previous secure and functional version of the baseline configuration.²⁵⁵ This plan can help an entity recover from a system or component update that is not functioning correctly. The plan can explain what to do (e.g., shut down, failover, or replace) if a service or component fails and how to resume secure operations on a redundant system while still providing uninterrupted service to end users. Entity personnel should consider the time required to perform rollback procedures and when to trigger the rollback plan. Entity personnel should establish rollback plan timing that minimizes business disruption.

Change implementation failures or incomplete changes can cause expensive damage to systems and components. One effective plan step is to minimize damage by identifying a stable recovery

²⁵⁴ Refer to CISA's [CRR Supplemental Resource Guide, Vol. 3: Configuration and Change Management, Version 1.1](#), and [CRR Supplemental Resource Guide, Vol. 5: Incident Management, Version 1.1](#). Also refer to NIST SP 800-128, [Guide for Security-Focused Configuration Management of Information Systems](#).

²⁵⁵ Refer to NIST SP 800-128, [Guide for Security-Focused Configuration Management of Information Systems](#).

point and archiving or imaging the system or component at that point. Entity personnel would develop and test related rollback procedures and identify spare systems and components (e.g., power supplies, system motherboards, hard drives, and communication switchboards) that may be needed, consistent with the criticality of the system or component. The entity documents the stable recovery point so multiple personnel can participate and view the same information during rollback (e.g., hardware, software, firmware, configuration files, and other configuration records).

It is important to control rollback tools because an unauthorized rollback could allow an attacker to restore a system or component to a prior vulnerable image, which in turn could allow the attacker to corrupt the system or component or inject malware. Effective management has appropriate security controls to prevent unauthorized rollback. The entity may have a special update process (e.g., physical presence of personnel) for rolling back the installed systems and components to an earlier version. This mechanism provides a dual control for management to guard against attackers using automation to install old systems and components with known vulnerabilities.

Effective management tracks and reports issues that lead to the use of a back-out plan and the effects of a failed or incomplete change deployment. Documentation of failed or incomplete deployments should include lessons learned for future change implementations.

VII.C End-of-Life

With respect to technology, EOL is a time frame usually defined by a technology vendor to describe when an asset has reached the end of its useful life cycle and when the vendor will no longer maintain and support the asset or continue to sell or license it. This is also applicable to a service provided in support of purchased IT assets. When the vendor no longer updates or plans to sunset services that support the IT asset or discontinues the sale of licensing of support services, this form of EOL is considered “end-of-service.”²⁵⁶ If the IT asset was created in-house, EOL occurs when the entity has decided to no longer update and otherwise maintain it.

A vendor generally determines the useful life of the IT assets it sells. The vendor identifies when it will stop providing updates and communicates a timeline along which it will sunset the systems and components. Entity personnel who purchase IT assets from vendors should evaluate the expected life of the IT asset as part of their due diligence. EOL considerations should occur as part of the initial contract negotiation and at contract renewal and be specified in the resulting contract. For example, the contract should contain a clause specifying the amount of advanced notice the vendor will provide the entity before it discontinues updates and other support of the IT asset. This notification is critical to the entity in planning replacements (including migrations from the legacy system to the replacement), and in planning for the off-boarding of the IT asset. Therefore, management should have a process to determine EOL decisions (e.g., replace, upgrade, or migrate to a new system) before a system’s or component’s EOL.

²⁵⁶ System, component, and service providers sometimes use the term “end-of-service” to indicate when maintenance services and updates will no longer be supported or provided.

If developed internally, the entity should plan for system or component obsolescence. Management, development staff, and users may have input into the system's or component's useful life timeline. If a system or component no longer meets users' needs, or maintenance costs are too high, management may conclude that the system or component has reached EOL and should be replaced.

The entity's IT asset inventory should have information about the useful life of IT assets in order for the entity to plan for orderly transitions from one system or component to another. An effective ITAM process includes monitoring each IT asset's depreciation and obsolescence schedule and planning well in advance for EOL. Items to consider in the process include the party responsible for development, version, patch levels (available and currently deployed), and the system's or component's expected life. An entity may leverage existing tools (e.g., depreciation schedule and IT asset inventory) to facilitate obsolescence planning and ensure that replacement resources have been provided for.

An IT asset that is obsolete and at EOL or end-of-service may be more vulnerable to exploitation; therefore, this risk should be managed to maintain confidentiality, integrity, availability, and resilience. With older and less resilient IT assets, an increased number of security vulnerabilities may result in greater risk of intrusion and exploitation (e.g., malware, ransomware, and data breaches). The potential impacts from these risks increases for interconnected systems and components because of the number and types of access points. These risks also exist for components provided by all parties in the supply chain. Continuously assessing the risks of using aging, outdated, and unsupported systems and components is the foundation for mitigating the risks. Effective risk mitigations include the following:

- Replacing systems and component in a timely manner.
- Establishing processes for vendors to notify the entity of component EOL status changes (e.g., end-of-production, end-of-service).
- Extending support from the vendor.²⁵⁷
- Adding or augmenting system or component controls:
 - Segregating the system or component from the network until it can be replaced or removed.
 - Locking down system or component devices and ports for access.
 - Increasing access controls and monitoring.
 - Minimizing connections to the system or component.

Management should consider EOL risks tied to maintaining legacy systems and components for extended periods of time. When continuing to use legacy systems, management should consider weaknesses related to the design, development, manufacturing, production, shipping and receiving, delivery, and operation of the system and component that can be exploited at EOL by

²⁵⁷ Third-party providers often charge additional fees to continue providing updates after a system's or component's EOL. Extending support beyond EOL may result in risks, such as operating systems and components with compounded vulnerabilities and diminishing availability of expertise.

a threat source.²⁵⁸ These legacy-related risks are two-fold. If management continues to use legacy systems or components, management puts its supply chain partners at risk; and if the entity's supply chain partners continue to operate legacy or unsupported systems or components, the entity may be at risk for EOL or end-of-support vulnerabilities. Effective management addresses EOL and the use of legacy systems and components and time frames for necessary replacement, upgrade, or migration in contracts between the entity and its supply chain partners.

For more information on ITAM and EOL, refer to *FFIEC IT Handbook's* "[Architecture, Infrastructure, and Operations](#)," "[Information Security](#)," "[Outsourcing Technology Services](#)," "[Business Continuity Management](#)," and "[Management](#)" booklets.

VII.D Termination and Disposal

When a system or component becomes obsolete, is no longer supported, no longer meets the users' or entity's needs, or becomes too costly to maintain, management may decide to terminate its use and dispose of the system or component. Effective management has appropriate termination and off-boarding procedures. The procedures should identify who has the responsibility to decide whether to terminate a vendor relationship, as well as an approval and acknowledgment process in which contracted parties agree to the relationship termination. Effective management negotiates contract clauses that specify termination criteria, including related to fourth or nth party relationships (e.g., affiliates, subcontractors) if necessary. It is important that the termination clauses address confidentiality, integrity, availability, and resilience of data and operations throughout the off-boarding process.

There are several important considerations when terminating a system, component, or service including disposing of decommissioned systems and components, and safely migrating and disposing of data and documentation. Data are particularly important when being transferred to a new replacement system to maintain confidentiality, integrity, availability, and resilience. Effective management has procedures for activities such as the following:

- Shutdown (i.e., sunset) of the systems and components.
- Identification of the tasks involved.
- Data identification and preservation (i.e., archival or transfer) or disposal.
- Secure disposal of unnecessary systems and components (e.g., hardware and software).

Effective management validates that appropriate personnel are aware of the procedures to coordinate the orderly disposition of the system, its components, and the data.²⁵⁹ The entity's critical or sensitive data and documents should be removed (e.g., wiped, sanitized, or otherwise destroyed) logically and physically from the system and components before disposal. This extends to any data or documents maintained by the third party on behalf of the entity, and effective management addresses the entity's requirements in the contract termination and disposal clauses.

²⁵⁸ Refer to "[CISA Insights – Cyber: Remediate Vulnerabilities for Internet-Accessible Systems](#)."

²⁵⁹ Refer to U.S. Department of Justice's *Systems Development Life Cycle Guidance Document*, chapter 12, "[Disposition Phase](#)."

VII.E Maintenance Documentation

Maintenance documentation provides valuable descriptions for the upkeep of an entity's systems and components and significantly enhances management's ability to maintain, operate, and administer IT assets. The larger and more dispersed an entity, the greater role documentation plays in effective maintenance across the entity. Advantages of documentation for users include access to operation manuals, training materials, and online application help features.

Documentation enhances IT personnel's ability to maintain and update systems efficiently, track updates to the systems and components, and identify and correct programming defects.

Developing and maintaining current and accurate maintenance documentation can be complicated, time-consuming, and expensive. However, maintaining standardized documentation and indexing procedures are important to help ensure the uniform accessibility of existing maintenance documentation. Authorized personnel should update the documentation with system, component, and configuration updates according to the entity's or third party's prescribed standards, as applicable. Effective management works with third parties to help ensure that the entity receives current system, component, and user maintenance documentation.